

Individual Design Contribution — Factor 2: Possession-Based One-Time Passwords

Group	Cryptix	Module	CS-3053 — Computer Security (Semester 5)
Student ID	230279R	Submission	1 — Individual Design Work
Student name	Jayasinghe E.A.T.D	Date	2026/09/15

1. Scope

My contribution to the group's MFA system is the **second factor** (*something you have*): TOTP enrolment and verification, an email OTP fallback, single-use backup codes, their storage design, the Factor-2 API surface, and the Factor-2 rows of the group threat model.

The design problem is not "add TOTP", which is solved. It is that **every mainstream TOTP enrolment flow is a QR code** — a purely visual artifact — and **every OTP verification requires transcribing a code**, which WCAG 2.2 classifies as a cognitive function test. Both exclude the target users. This document shows how the second factor is made completable with the monitor off without weakening the security properties that make a possession factor worth having.

Out of scope (other members, referenced only at interfaces): Factor 1 and accounts (M1), WebAuthn (M3), client screens and ARIA (M4), orchestration, rate-limit middleware, audit log and CSRF (M5).

Notation: UML 2.5 component, state-machine and sequence diagrams; crow's-foot ER. MUST/SHOULD/MAY per RFC 2119 [1]. Requirements are `FR-n`, `SR-n`, `AR-n`; design decisions `DD-nn` (§8).

2. Assumptions

Each assumption is given with its basis and the consequence if it proves false.

#	Assumption	Basis → consequence if false
A1	Users are blind or have low vision and are competent daily screen-reader or braille-display users.	The system supports AT, it does not replace it [2]. → A non-AT channel (e.g. telephone) would be needed; out of scope.
A2	Users can run an accessible TOTP authenticator app.	Mainstream authenticators ship with labelled controls and platform AT support. → Covered by the email OTP and backup-code paths; no user is locked out.
A3	Users control an email account readable with their own AT.	Email is already required by M1's account design. → User falls back to backup codes or M3's passkey.
A4	Authenticator device clocks are within ±60 s of true time.	Devices sync by NTP; RFC 6238 §6 anticipates drift and provides resynchronisation [3]. → The ±1-step window plus stored per-user drift absorbs it; beyond that, re-enrol.
A5	All traffic uses HTTPS (TLS 1.2+).	Transport security is M5's responsibility and a stated project principle. → Every OTP becomes interceptable. This assumption is load-bearing.
A6	Identity proofing is out of scope; the target is authentication assurance (NIST AAL2), not identity assurance.	The brief asks for an authentication system. → None; this is a scope boundary, not a security claim.
A7	Users may authenticate in public places where audio can be overheard.	Screen-reader users routinely work in shared spaces; basis of group threat T7. → The audio-privacy controls (§6.3) become redundant, not harmful.
A8	No HSM is available; encryption keys are held in process environment configuration.	Standard coursework deployment constraint. → None; disclosed as residual risk R3 rather than hidden.
A9	Email delivery is best-effort and may take minutes.	SMTP guarantees no delivery time. → The 10-minute validity would have to grow, weakening the control. This is why email is a fallback, not the primary channel.
A10	A user enrolls at most one TOTP authenticator.	Scope limit. → <code>totp_credential1</code> becomes one-to-many; no other component changes.
A11	The user's OS, browser and screen reader are not compromised.	Consistent with the group model's out-of-scope list. → Malware could capture the secret at enrolment; this is precisely why Factor 3 exists.
A12	Anything spoken is also present as DOM text.	Braille users read text and do not use speech. → Deaf-blind users excluded entirely. Treated as a hard constraint, not a preference.

Assumptions deliberately not made: that a sighted helper is available; that the user can scan a QR code with a camera app; that a smartphone exists; or that the user can hear. Each would have simplified the design by excluding part of the target population.

3. Requirements

ID	Requirement	Verified by
FR-1	Enrol a TOTP authenticator with no visual artifact required.	T1, T9
FR-2	Enrolment does not complete until the user returns one valid code.	T2
FR-3	Verify a 6-digit TOTP at login and report the next required factor.	T3
FR-4	Offer an emailed OTP to users without an authenticator app.	T6
FR-5	Issue single-use backup codes; allow regeneration; announce how many remain.	T7
SR-1	Shared secret ≥ 128 bits from a CSPRNG.	T1
SR-2	An accepted OTP is never accepted twice.	T4
SR-3	Consecutive failures are throttled and hard-capped.	T5
SR-4	TOTP secrets encrypted at rest; backup codes and email OTPs unrecoverable from the database.	T1
SR-5	All code comparisons constant-time.	T8
SR-6	No response reveals whether a user exists or is enrolled.	T8
AR-1	The QR code is optional; a text route always exists. — WCAG SC 1.1.1 (A) [4]	T9
AR-2	No step requires transcription without an assisting mechanism; paste is never blocked. — SC 3.3.8 (AA) [4]	T10
AR-3	No application-imposed time limit beyond the cryptographically essential one. — SC 2.2.1 (A) [4]	§6.2
AR-4	Outcomes announced to AT without moving focus. — SC 4.1.3 (AA) [4]	T11
AR-5	Every error states what happened and the corrective action. — SC 3.3.1 (A), 3.3.3 (AA) [4]	§5.4
AR-6	Secrets are never spoken automatically.	T12
AR-7	Every flow operable by keyboard alone. — SC 2.1.1 (A) [4]	T9

4. Architecture and Data Design

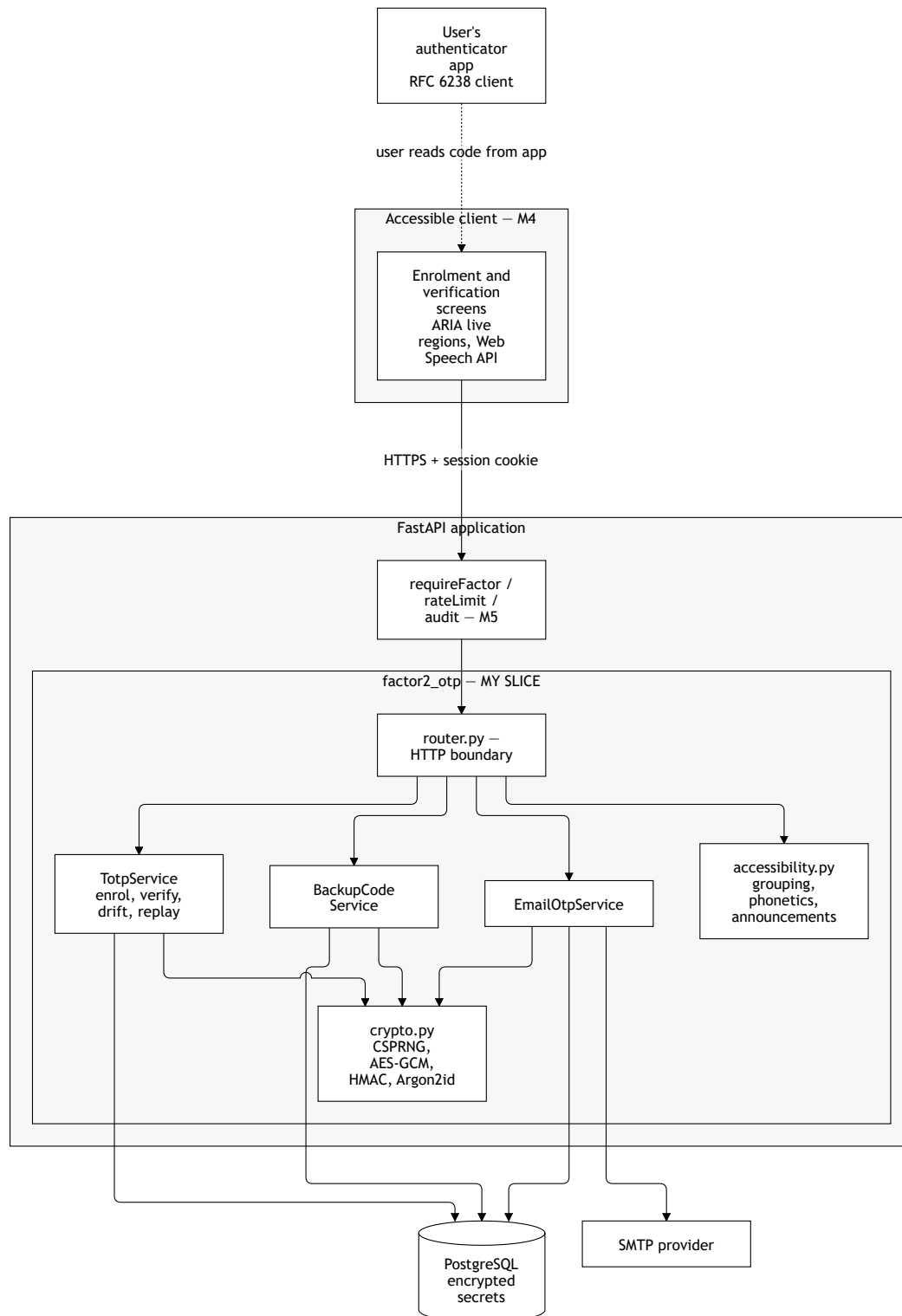


Figure 1 — Component decomposition of the Factor-2 slice.

- The **dashed arrow is out-of-band**: the authenticator app never contacts the server. The secret is transferred once at enrolment and both sides then compute codes independently. This is the property that makes TOTP a possession factor at all.
- **router.py** is the only module aware of HTTP, so services are unit-testable without a client.
- **accessibility.py** is a **first-class module, not a view concern** — the grouped and phonetic rendering of a secret is security-relevant output, so it is generated and tested server-side rather than improvised by the client.
- Lockout and rate limiting are **M5 middleware in front of my router**; I do not reimplement them.

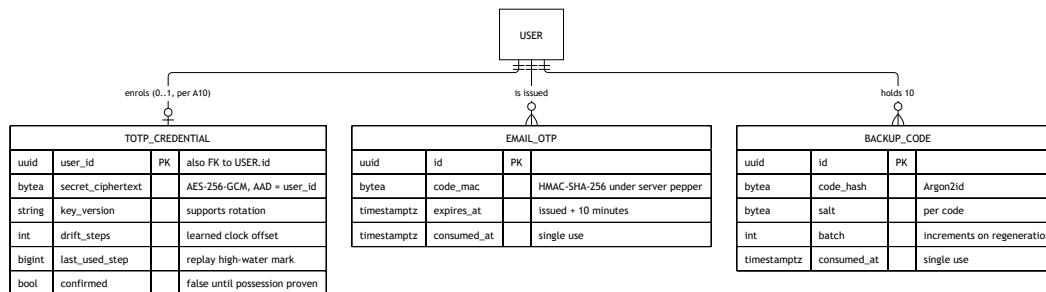


Figure 2 — Factor-2 data model. **USER** is M1's table, shown for context.

- The TOTP secret is encrypted, not hashed. A shared secret must be recovered in plaintext to recompute the code, so hashing is impossible. This asymmetry with Factor 1 storage is why key management carries the weight here that password hashing carries for M1.
- **user_id** is bound into the AES-GCM additional authenticated data, so a ciphertext copied from one user's row into another's fails to decrypt — defeating a database-level credential swap.
- Backup codes are hashed and never encrypted: the verifier only compares, never recovers.
- **last_used_step** is a high-water mark, not a list of used codes: rejecting any step at or below it blocks replay in constant space and also rejects older still-in-window codes.
- **confirmed** makes an unproven enrolment inert, closing the window in which an interrupted enrolment leaves a usable credential behind.

Secret	Size	Entropy	At rest	Basis
TOTP shared secret	160-bit, Base32 [11]	160 bits	AES-256-GCM	RFC 4226 §4 R6 requires ≥ 128 bits, recommends 160 [5]
Email OTP	8 decimal digits	26.6 bits	HMAC-SHA-256 + pepper	NIST SP 800-63B §5.1.3.2 requires ≥ 20 bits; 6 digits gives only 19.9 [6]
Backup code	16 decimal digits, 4-4-4-4	53.2 bits	Argon2id, salted	SP 800-63B §5.1.2.2: look-up secrets below 112 bits must be salted and stretched [6]

Per **A8** both the data-encryption key and the pepper come from environment configuration, not an HSM. SP 800-63B §5.1.4.2 requires OTP verification keys to be stored encrypted with the decryption key protected [6]; this is a weaker but honest realisation, recorded as residual risk R3.

Accessible TOTP enrolment with three-tier secret delivery.

- A **wider window (± 2)** is used at enrolment only, to absorb a clock already offset before the first code is generated. The measured offset is stored and applied at every later verification, letting the **login** window stay at the RFC-recommended ± 1 step [3, §5.2]. RFC 6238 §6 explicitly provides for this resynchronisation.
- `qrPng` is returned **last and is optional** — for a sighted helper or residual vision. It is never the only route (AR-1), because WCAG SC 1.1.1 requires a text alternative for non-text content [4].
- The **headphone warning precedes any offer to speak**, mitigating threat T7.

TOTP verification, showing the replay guard and throttle path.

- **Replay is distinguished from invalidity.** A replay is evidence of interception; an invalid code is usually a typo. The user-facing messages differ too, because "already used, wait for the next one" is actionable whereas a generic failure leaves a non-sighted user with nothing on screen to consult (AR-5). RFC 6238 §5.2 requires that a validated OTP not be accepted again [3].
- The throttle message **names the alternative**. A lockout with no stated exit is a dead end, and disproportionately damaging when the user cannot visually scan the page for another option.

Email OTP and backup codes. The email OTP is 8 digits, valid 10 minutes, single use, delivered as **plain text with the code in the subject line** — a screen reader announces the subject in the message list, so the user need not open or navigate the message, and HTML email is a common AT obstacle. `/mfa/email/send` always returns `202` regardless of whether the account exists (SR-6). Backup-code verification strips spaces and hyphens before comparison, so a user who types the grouping they heard is not penalised, and announces the remaining count — **warning at three or fewer**, because a screen-reader user has no ambient view of a dwindling list and would otherwise discover exhaustion only at the moment of lockout.

6. Accessible Interaction Design

6.1 The enrolment transcription problem

A QR code is unusable without sight, and the usual alternative — "can't scan? type this key" — replaces a visual barrier with a transcription barrier of 32 Base32 characters.

Secret delivery tiers, ordered by transcription burden. Bold outlines mark the preferred zero-transcription tiers; the dashed outline marks the fallback.

- The core accessibility claim is that **Tiers 1 and 2 eliminate transcription entirely**, which is exactly what WCAG SC 3.3.8 asks for: a *mechanism* assisting the user with what would otherwise be a cognitive function test [4]. Tier 3 is the safety net, not

- the plan.
- Tier 3 is **replayable group by group** (keys `1–8` repeat a group), so the user never has to hold 32 characters in working memory or restart after one missed character.
 - **NATO phonetics** are used because Base32 letters are aurally confusable (B/D/E/G/P/T/V/Z all rhyme in English TTS); phonetic spelling was standardised for exactly this problem.
 - Grouped text is **always in the DOM** (A12), so braille users receive the same content.

6.2 Input design and time limits

Property	Value	Reason
<code>autocomplete</code>	<code>one-time-code</code>	Standard autofill field name [7]; lets the platform supply the code, removing transcription — the SC 3.3.8 <i>mechanism</i> .
Paste	Never blocked	Blocking paste is the commonest SC 3.3.8 failure; it converts a solved problem back into a cognitive function test [4].
Whitespace, hyphens	Stripped server-side	The user hears grouped digits and may type them grouped.
Digit announcement	<code>aria-label</code> exposes digits separately	Screen readers otherwise read <code>123456</code> as "one hundred twenty-three thousand...", which is unusable for verification.

A TOTP expires every 30 seconds, which resembles a WCAG SC 2.2.1 violation. It is not: SC 2.2.1's **Essential Exception** covers limits where extending them would invalidate the activity [4], and extending an OTP's life extends the attacker's window by the same amount. The design therefore adds **no limit of its own** — no countdown, no progress bar, no auto-dismissal (DD-14). The user may take as long as they need because a new code is always available; the failure mode is a retry, not a lost session, and the error message says so.

6.3 Audio privacy

Because audio can be overheard (A7, threat T7): secrets are **never spoken automatically**; speech requires a deliberate keystroke preceded by "*The next content is secret. Use headphones if you are not alone.*"; and a **silent route always exists** (Tiers 1–2), so a user in public is never forced to choose between security and access. The server never speaks a TOTP code — it never has one — which confines this threat to enrolment.

7. Security Design

7.1 Threats owned by this slice

ID	STRIDE	Threat	Mitigation
T2	Spoofing	TOTP brute force	6 digits, ± 1 step, soft lockout and a hard cap on consecutive failures (§7.2)
T3	Spoofing	Real-time OTP phishing	Short validity, single use, audit trail. Not fully mitigable — see R2
T7	Info disclosure	Spoken secret overheard	Never auto-speak; headphone warning; silent alternatives (§6.3)
T8	Info disclosure	Database disclosure	AES-256-GCM with AAD binding; Argon2id; peppered MAC
T11	Elevation	OTP replay	<code>last_used_step</code> high-water mark; single-use flags
T15	Info disclosure	<i>Enumeration of enrolled users</i>	Uniform <code>202</code> ; enrolment state never leaks before Factor 1
T16	Spoofing	<i>Compromised email account yields Factor 2</i>	Fallback only; tighter rate limit; audit-tagged channel
T17	Elevation	<i>Backup-code precomputation from a dump</i>	Per-code salt + Argon2id; no unsalted lookup index
T18	Info disclosure	<i>Timing side channel</i>	<code>hmac.compare_digest</code> ; identical response shape and timing

Rows T15–T18 are new threats identified during this design work and are contributed back to the group model. Cryptographic choices: HMAC-SHA-1 / 6 digits / 30 s per RFC 6238 defaults [3]; AES-256-GCM for the secret; Argon2id at OWASP's minimum of $m = 19$ MiB, $t = 2$, $p = 1$ [8, 9] for backup codes; HMAC-SHA-256 under a server pepper for email OTPs.

7.2 Why a timed lockout alone is insufficient

With 6 digits and a ± 1 -step window, three codes are valid at any instant, so a single guess succeeds with probability $3 / 10^6 = 3 \times 10^{-6}$.

Control regime	Attempts available	Cumulative success probability
No throttling, 1 per second	~86 400 / day	~23 % per day — unacceptable
5 attempts per 15-minute lockout only	480 / day	~0.14 % per day, ≈4 % over 30 days — still unacceptable
The above plus a 100-consecutive-failure hard cap	≤100 lifetime consecutive	≤0.03 % — acceptable

This is the quantitative reason the state machine has both `SoftLocked` and `HardLocked` states. NIST SP 800-63B §5.2.2 caps consecutive failed attempts at 100 [6]; the analysis shows *why* that control, rather than the rate limit, is what actually bounds the attacker. Two refinements follow: consecutive counters reset on success, so a second non-resetting rolling 24-hour counter

(cap 50) closes the reset trick; and lockout is keyed on **user and source IP** so an attacker cannot lock a victim out from elsewhere (threat T10, M5).

7.3 Residual risks accepted

ID	Risk	Why accepted / compensating control
R1	Email OTP is not a true possession factor and is expressly excluded by SP 800-63B §5.1.3.1 [6].	Excluding users who cannot run an authenticator app (A2) fails the brief's core purpose. Fallback only, tighter limits, audit-tagged, users steered to TOTP or Factor 3.
R2	TOTP is not phishing-resistant : a real-time proxy can relay a code.	Inherent to all shared-secret OTP schemes. Factor 3 (origin-bound WebAuthn) exists to cover this; short window and audit logging limit exploitation.
R3	Keys live in environment configuration, not an HSM (A8).	No HSM in an academic deployment. AAD binding and <code>key_version</code> rotation support; production upgrade path documented.
R4	Losing phone, backup codes and email access leaves no self-recovery.	Any path surviving total factor loss is itself an attack path. Mitigated by the low-stock warning at three codes.

8. Design Decisions and Justifications

ID	Decision	Justification (alternatives rejected)	Ref
DD-01	TOTP (RFC 6238) as primary second factor.	HOTP desynchronises when codes are generated but unused, and recovering from desync is a poor experience without sight. SMS is classed RESTRICTED by NIST for SS7 and SIM-swap risk.	[3] [6]
DD-02	160-bit shared secret.	RFC 4226 §4 R6 mandates ≥128 bits and recommends 160.	[5]
DD-03	6 digits, 30-second step.	Deployed authenticator apps assume the RFC defaults; deviating breaks interoperability, and a broken enrolment is total access failure for this user group. Entropy loss is offset by throttling (§7.2).	[3] [5]
DD-04	±1-step verification window, with per-user drift learned at enrolment (t±2).	RFC 6238 §5.2 recommends at most one step for network delay; §6 provides for resynchronisation. Each extra step raises guessing probability linearly.	[3]
DD-05	Retain HMAC-SHA-1.	Interoperability: many apps ignore the <code>algorithm</code> parameter. SHA-1 collision attacks do not affect HMAC, whose security rests on PRF properties. Logged as technical debt with a rotation path.	[3] [5]
DD-06	Three-tier secret delivery (deep link → clipboard → spoken phonetic).	Tiers 1–2 reduce transcription to zero, satisfying SC 3.3.8; QR alone fails SC 1.1.1.	[4]
DD-07	Mandatory confirm step before an enrolment counts.	Prevents self-lockout — the highest-impact usability failure in the slice (FR-2).	—
DD-08	Email OTP is a fallback, never a peer of TOTP.	SP 800-63B §5.1.3.1 excludes email from out-of-band authentication because it proves no specific device; omitting it entirely would exclude users covered by A2. Residual risk R1.	[6]
DD-09	Email OTP is 8 digits, valid 10 minutes, single use.	6 digits gives 19.9 bits, below NIST's 20-bit floor for out-of-band secrets; 10 minutes is NIST's stated maximum validity.	[6]
DD-10	Code in the email subject line , plain text.	A screen reader announces the subject in the message list, so the user acts without opening the message; HTML email is a common AT navigation obstacle.	[2]
DD-11	Email OTPs stored as HMAC under a server-side pepper.	26.6 bits is trivially brute-forced offline from a plain digest; the pepper is not in the database, so a database-only compromise cannot recover codes.	[8]
DD-12	Backup codes are 16 decimal digits , stored with Argon2id.	Accessibility-driven: decimal digits are unambiguous in every TTS voice, whereas Base32 letters are aurally confusable; digits also suit the numeric keypad used for M1's PIN option. 53 bits is below NIST's 112-bit threshold, so salting and stretching are required.	[6] [8] [9]
DD-13	Replay guard by high-water mark (<code>last_used_step</code>).	RFC 6238 §5.2 forbids re-acceptance of a validated OTP; a high-water mark achieves this in constant space and also rejects older in-window codes.	[3]
DD-14	No application-imposed time limit; no countdown UI.	SC 2.2.1's Essential Exception covers the cryptographic limit, but an added countdown would impose real time pressure for no security gain.	[4]
DD-15	Hard cap on consecutive failures in addition to timed lockout.	Quantified in §7.2: a timed lockout alone leaves ~4 % success over 30 days; the consecutive cap bounds it at ~0.03 %. Required by SP 800-63B §5.2.2.	[6]
DD-16	Announcement strings generated server-side and returned with every response.	Puts spoken wording under the same review and test regime as the security logic, and keeps messages consistent across screens (AR-5).	[4]

API surface (refines the Member-2 rows of `docs/api-contract.md`): `POST /mfa/totp/enroll`, `POST /mfa/totp/confirm` [new], `POST /mfa/totp/verify`, `DELETE /mfa/totp` [new], `POST /mfa/email/send`, `POST /mfa/email/verify`, `POST /mfa/backup/generate`, `POST /mfa/backup/verify`. Every response carries `{next, announcement}`; every error carries a machine code and a sentence that makes sense spoken with no visual context (DD-16). The confirm endpoint is new because, without it, an enrolment can be recorded that the user's app never received.

9. Verification Plan

ID	Test	Method	Verifies
T1	160-bit secret, valid Base32, well-formed <code>otpauth://</code> URI; ciphertext undecryptable under another <code>user_id</code>	Unit	SR-1, SR-4, DD-02
T2	Unconfirmed credential cannot satisfy Factor 2	Unit	FR-2, DD-07
T3	Steps t-1, t, t+1 accepted; t±2 rejected at login; enrolment tolerates t±2 and stores drift	Unit, frozen clock	FR-3, DD-04
T4	A code accepted once is rejected on immediate resubmission	Unit	SR-2, T11
T5	6th consecutive failure returns 429; 101st hard-locks	Integration	SR-3, DD-15
T6	Email OTP expires at exactly 10 minutes and cannot be reused	Unit	FR-4, DD-09
T7	Backup code single-use; regeneration invalidates the old batch; low-stock warning at three	Unit	FR-5
T8	<code>/mfa/email/send</code> returns 202 with equal timing for existing and unknown users	Integration	SR-5, SR-6
T9	Full enrolment and login completed with NVDA and the monitor switched off	Manual	AR-1, AR-7 — headline acceptance test
T10	Paste works; <code>one-time-code</code> autofill is offered	Manual	AR-2, DD-06
T11	Announcements reach the live region without moving focus; code field announced digit-by-digit	Manual, NVDA + JAWS	AR-4, §6.2
T12	Spoken secret never emitted without a deliberate keystroke	Manual	AR-6, T7
T13	Brute-force and replay scripts against <code>/mfa/totp/verify</code>	Attack test, with M5	T2, T11

10. References

- Bradner, S. *Key words for use in RFCs to Indicate Requirement Levels*. RFC 2119, IETF, 1997. <https://www.rfc-editor.org/rfc/rfc2119>
- WebAIM. *Screen Reader User Survey*. Utah State University. <https://webaim.org/projects/screenreadersurvey/>
- M'Raihi, D. et al. *TOTP: Time-Based One-Time Password Algorithm*. RFC 6238, IETF, 2011. <https://www.rfc-editor.org/rfc/rfc6238>
- W3C. *Web Content Accessibility Guidelines (WCAG) 2.2*. <https://www.w3.org/TR/WCAG22/> — and *Understanding SC 3.3.8 Accessible Authentication (Minimum)*. <https://www.w3.org/WAI/WCAG22/Understanding/accessible-authentication-minimum.html>
- M'Raihi, D. et al. *HOTP: An HMAC-Based One-Time Password Algorithm*. RFC 4226, IETF, 2005. <https://www.rfc-editor.org/rfc/rfc4226>
- Grassi, P. et al. *Digital Identity Guidelines: Authentication and Lifecycle Management*. NIST SP 800-63B. <https://pages.nist.gov/800-63-3/sp800-63b.html>
- WHATWG. *HTML Living Standard — Autofill field names (`one-time-code`)*. <https://html.spec.whatwg.org/multipage/form-control-infrastructure.html#autofill>
- OWASP. *Password Storage and Multifactor Authentication Cheat Sheets*. https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html
- Biryukov, A. et al. *Argon2 Memory-Hard Function for Password Hashing*. RFC 9106, IETF, 2021. <https://www.rfc-editor.org/rfc/rfc9106>
- OWASP. *Authentication Cheat Sheet*. https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html
- Josefsson, S. *The Base16, Base32, and Base64 Data Encodings*. RFC 4648, IETF, 2006. <https://www.rfc-editor.org/rfc/rfc4648>
- Google. *Key URI Format (otpauth:// scheme)*. <https://github.com/google/google-authenticator/wiki/Key-Uri-Format>